

Advanced Cyber Security Assignment

SS*ZG681 / SE*ZG681

B.1

- **Student Full Name:** Pallotu Devisri
 - **Student ID:** 2024AB12507
 - **Years of Professional Experience:** 3 years
 - **Current Role:** Software Developer
 - **Industry Domain:** Aerospace
 - **Selected System Name:** Aerospace Assembly Telemetry Platform
 - **System Type:** Simulated enterprise architecture
-
- **Student Full Name:** Vijayalaxmi Metgud
 - **Student ID:** 2024AB12508
 - **Years of Professional Experience:** 7.5 years
 - **Current Role:** Data Analyst
 - **Industry Domain:** Aerospace
 - **Selected System Name:** Aerospace Assembly Telemetry Platform
 - **System Type:** Simulated enterprise architecture

Confidentiality Statement: This report does not disclose proprietary or sensitive organizational information.

Executive Summary

This report evaluates the security posture of an Aerospace Final Assembly Line (FAL) Telemetry Platform, an Industry 4.0 IoT pipeline used for logging structural Quality Assurance (QA) passes during commercial aircraft fuselage mating. The system includes smart drilling units, an enterprise edge gateway, a factory-floor MQTT message broker, and a Live Defense Dashboard. This report analyzes the severe risks of MQTT Topic Spoofing and insider key compromise on the factory floor. The proposed target state implements edge-based HMAC-SHA256 payload signing, UUID replay detection, and an Unsupervised Machine Learning (Isolation Forest) Anomaly Detection Engine to mathematically guarantee the integrity of structural QA telemetry before aircraft proceed to flight testing.

B.2 Anchor — System and Threat Surface Blueprinting

1. System Description

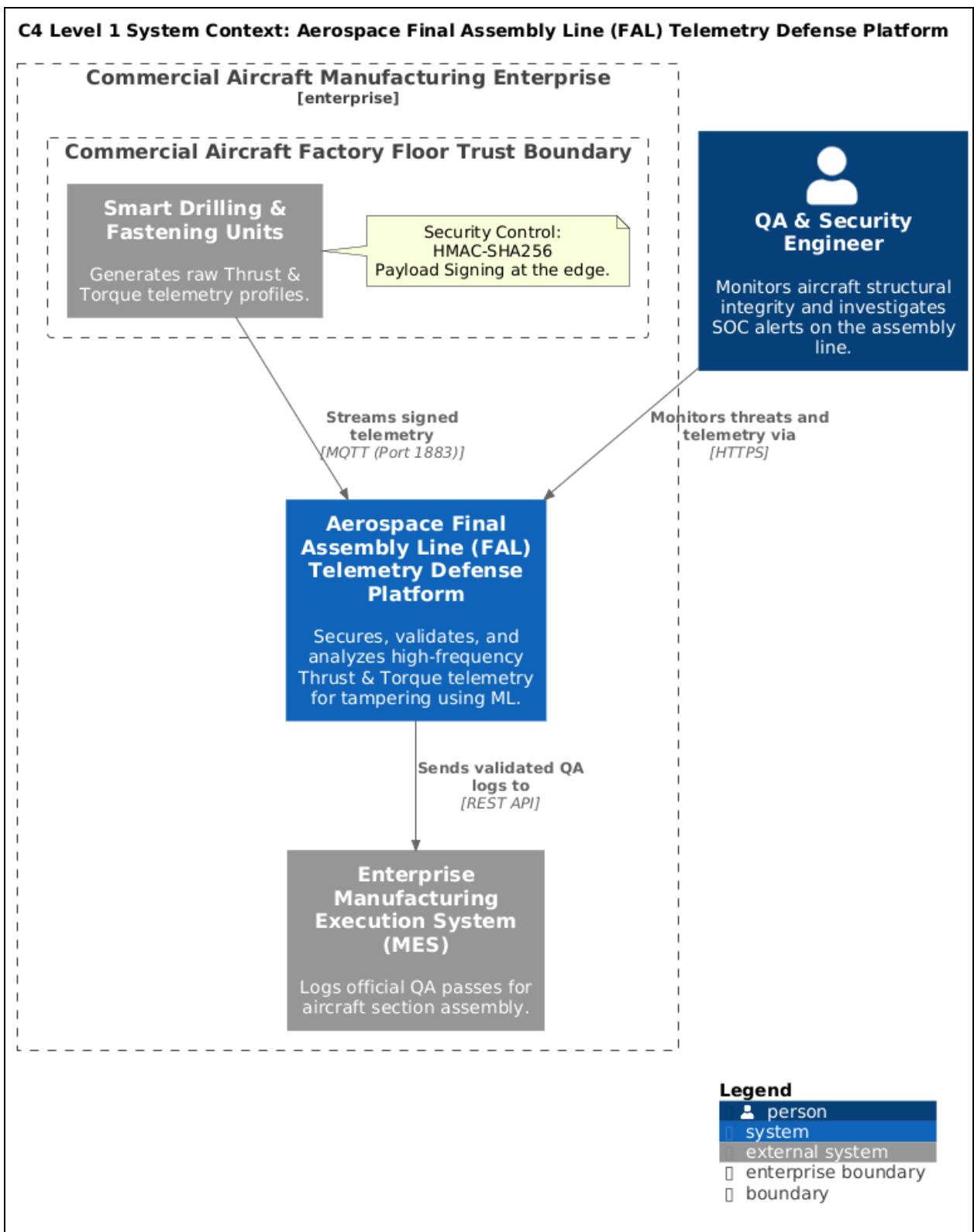
Aircraft section assembly on the FAL requires precision automated tools (e.g., smart drilling and fastening units for carbon-fiber reinforced joints). These tools stream live, high-frequency telemetry—specifically Torque and Thrust profiles—directly to the Enterprise Manufacturing Execution System (MES) to verify structural integrity and officially log QA passes. The system is operationally critical; falsified QA data can lead to catastrophic aircraft failures and global fleet groundings.

2. Runtime Architecture

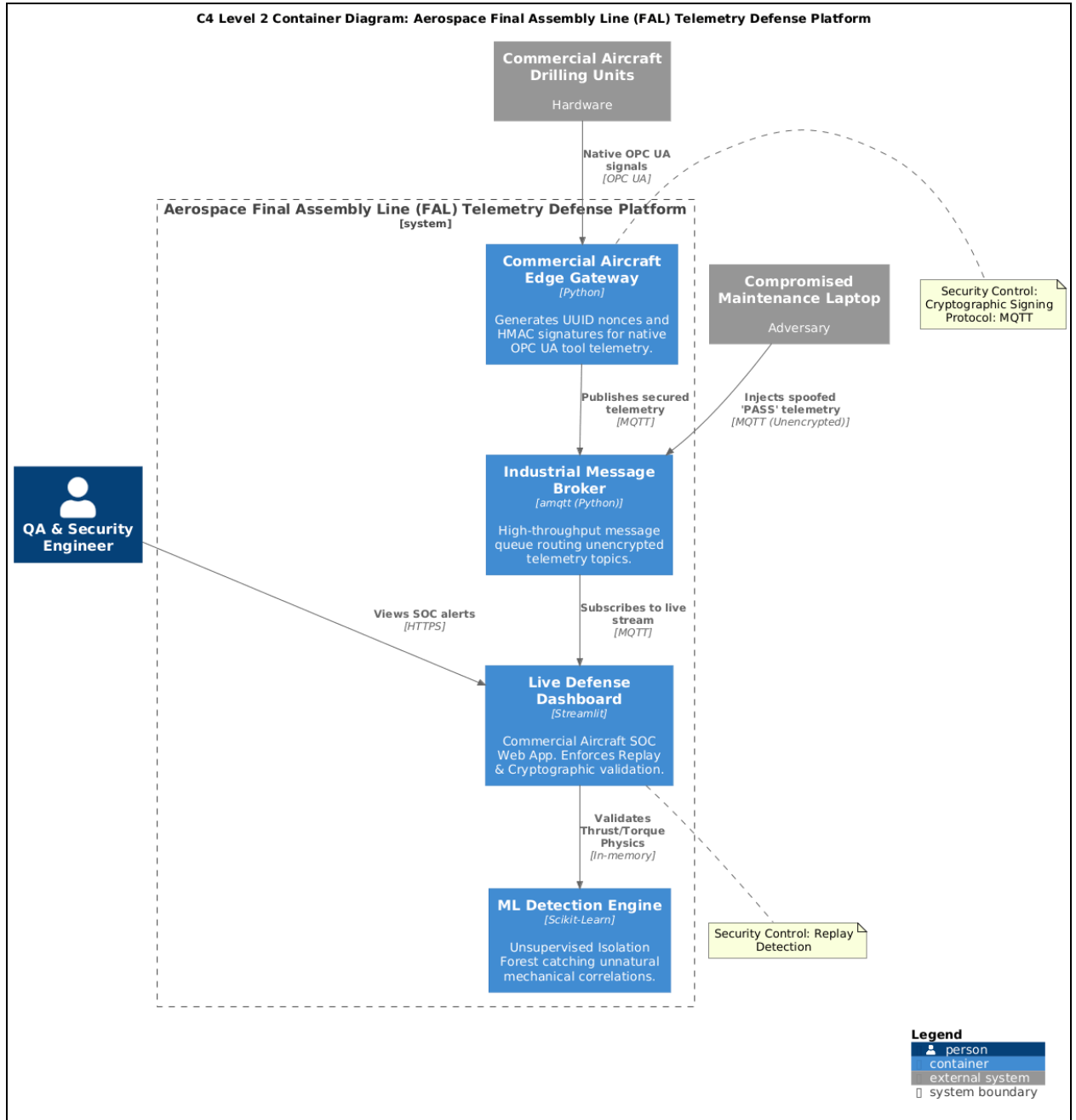
The system consists of physical smart tools generating native OPC UA telemetry on the factory floor. This data is bridged via an Edge Gateway to an unencrypted MQTT message broker for high-speed transmission. The Enterprise MES and a Python-based Streamlit Live Defense Dashboard subscribe to this broker to process the logs and run real-time Machine Learning anomaly detection algorithms.

3. C4 Diagrams

- **System Context (Level 1):**

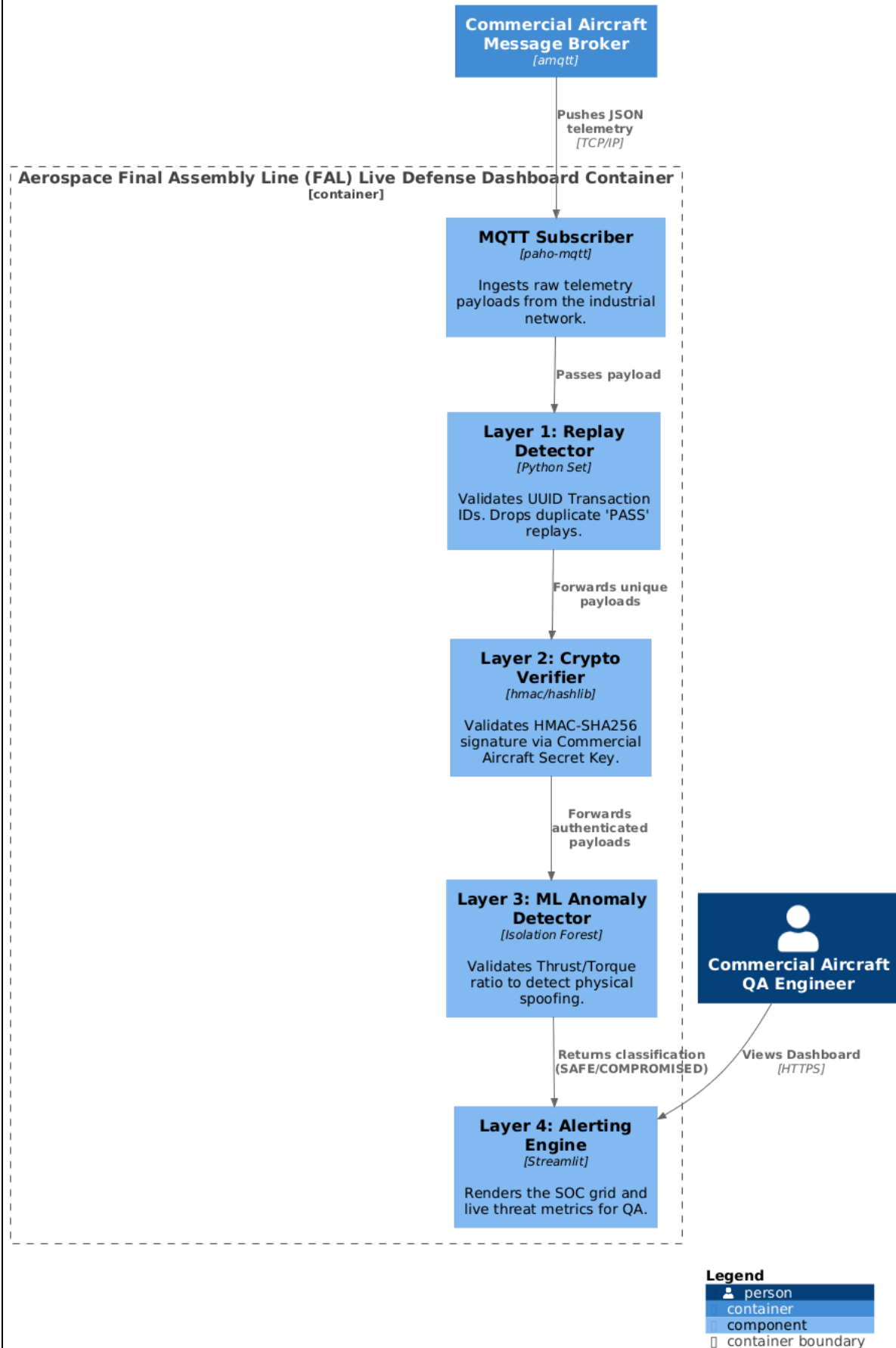


- **Container (Level 2):**



- **Component (Level 3):**

C4 Level 3 Component Diagram: Aerospace Final Assembly Line (FAL) Live Defense Dashboard



4. Data Flow Mapping

Source	Destination	Protocol	Data Type	Trust Boundary
Smart Tool	Edge Gateway	OPC UA	Raw Thrust/Torque	Hardware to Edge Boundary
Edge Gateway	Factory MQTT Broker	MQTT	HMAC-Signed JSON	FAL Network Boundary
Factory MQTT Broker	Enterprise MES / SOC Dashboard	MQTT	Validated QA Logs	Factory Floor to Enterprise IT

5. Data Classification Matrix

Asset / Data Element	Description	Criticality	Confidentiality Impact	Integrity Impact	Availability Impact	Owner	Regulation / Policy	Retention	Controls Required
Tool Telemetry	Thrust & Torque physics data	High	Low	High	Medium	FAL Engineering	Enterprise Safety Policy	7 Years	HMAC Signing, UUID Nonces, ML Validation

Structural QA Logs	Official joint verification passes	Critical	Low	Critical	High	Aviation QA Director	EASA Part 21G Compliance	50 Years	Immutable logs, Cryptographic verification
--------------------	------------------------------------	----------	-----	----------	------	----------------------	--------------------------	----------	--

6. Regulatory and Compliance Boundary

The system processes structural verification data directly governed by strict Aviation safety and operational compliance requirements, specifically EASA (European Union Aviation Safety Agency) and FAA manufacturing standards. Falsifying this data violates AS9100 quality certifications, exposing the manufacturer to massive regulatory penalties, revoked production certificates, and catastrophic safety liabilities.

B.3 Task 1 — CIA Asset Valuation and Cryptographic Policy

Confidentiality Failure Scenario

If the unencrypted MQTT network is monitored by an unauthorized party (e.g., via a compromised maintenance laptop on the FAL), attackers can map the telemetry payload structures and gather intelligence on factory floor operations to prepare for active injection attacks.

Integrity Failure Scenario

If an attacker executes an MQTT Topic Spoofing attack, they can fraudulently alter a failing torque value to a "PASS" to hide a defective carbon-fiber drill hole. This allows a critically flawed aircraft fuselage to bypass QA, severely compromising aircraft safety.

Availability Failure Scenario

If an attacker floods the factory MQTT broker with spoofed messages, the MES logging pipeline crashes, forcing the automated assembly line to halt production due to missing tool verifications, costing millions per hour in delays.

Business Impact

Catastrophic safety failures, loss of life, EASA/FAA fleet groundings, extreme legal liability, and irreversible reputational destruction for the manufacturer.

Security Models

- **Biba Integrity Model:** Selected and justified because the integrity of the QA logs (preventing unauthorized modification and spoofing of physical assembly data) is strictly prioritized over data confidentiality.

Cryptographic Policy

- **Data at rest:** AES-256 encryption for historical QA logs stored in the Enterprise MES and cloud data lakes.
- **Data in transit:** TLS 1.3 for all enterprise IT connections; MQTT payloads signed with HMAC-SHA256 over local factory networks.
- **Data in use:** Real-time memory validation by the Python Isolation Forest ML model.
- **Key management:** Centralized Enterprise KMS used to provision and rotate the secret HMAC keys to the edge gateways on the assembly line.
- **Certificate lifecycle:** Automated 90-day rotation for TLS certificates via the internal enterprise CA.
- **Logging and audit:** Immutable, append-only audit logging of all cryptographic verification failures and ML anomaly detections to the enterprise SOC.

B.3 Task 2 — Threat Modeling and Attack Graphs

Threat Scenario 1: MQTT Topic Spoofing (Tampering)

Attack Graph Table

Stage	Attacker Action	Target Component	Weakness Exploited	Evidence/Logs	Detection/Control	Mitigation

Reconnaissance	Sniff unencrypted topics	Factory MQTT Broker	Unencrypted industrial protocol (Plaintext)	Network traffic captures	Network Segmentation	Isolate factory VLAN
Initial Access	Compromise maintenance laptop	Factory Local Network	Weak physical/network access controls	DHCP logs, switch port access	Network Access Control (NAC)	Zero Trust Network Access
Execution	Inject spoofed 'PASS' payload	Enterprise MES Logging Pipeline	No cryptographic payload integrity	Broker connection logs	Cryptographic Verifier	HMAC-SHA256 Edge Signing
Impact	Poison aircraft QA analytics	Enterprise MES	Implicit trust of network data	Database mismatch	ML Anomaly Detection	Isolation Forest Physics Check

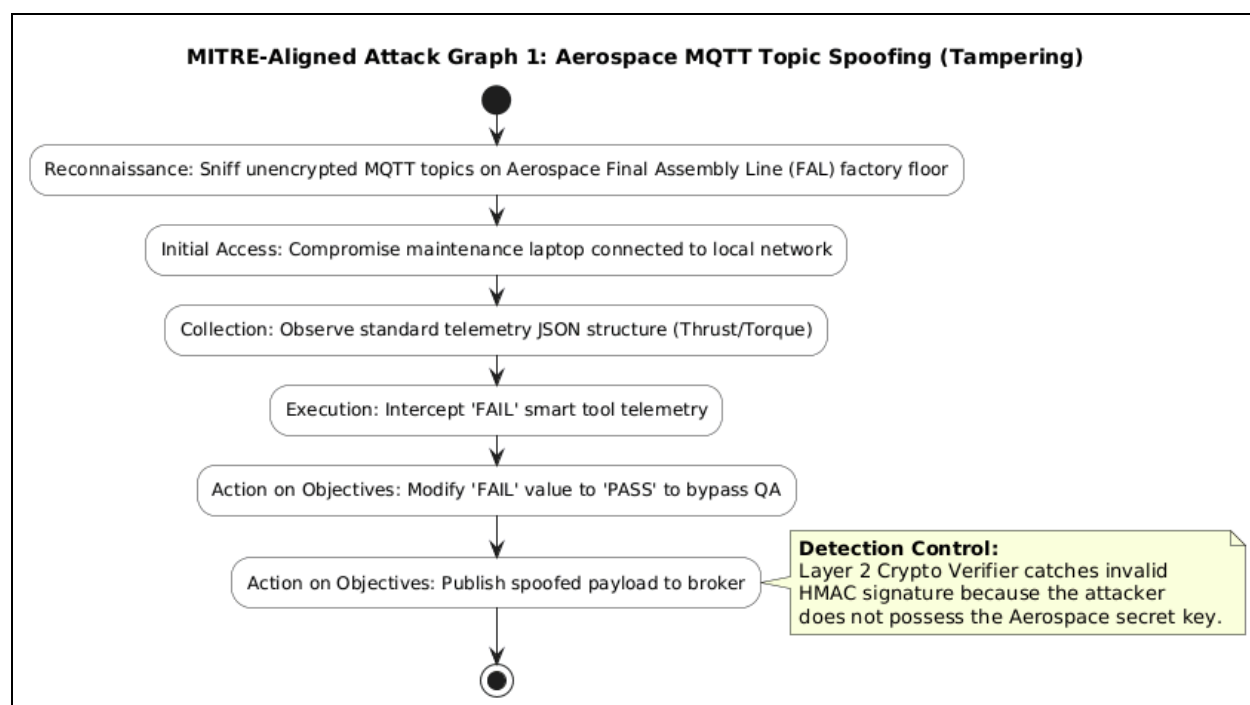
Threat Actor

External attacker or malicious insider with local network access to the Aerospace Final Assembly Line (FAL).

Objective

Manipulation (fraudulently altering a failing tool log to bypass QA and meet production quotas).

Attack Graph



Affected Assets

Aerospace MQTT Broker, MES QA Logs, Streamlit Dashboard.

Detection Opportunities

Cryptographic signature mismatches; unexpected spikes in MQTT publishing rates.

Existing Weaknesses

Legacy telemetry travels over local industrial networks completely unencrypted and unsigned.

Threat Scenario 2: Insider Threat (Key Compromise)

Attack Graph Table

Stage	Attacker Action	Target Component	Weakness Exploited	Evidence/Logs	Detection/Control	Mitigation

Initial Access	Steal HMAC Secret Key	Edge Gateway / KMS	Excessive insider privileges	Key access logs	Role-Based Access Control	Least privilege, secure enclaves
Defense Evasion	Forge UUID to bypass Replay block	Layer 1 Replay Detector	Valid cryptographic state, but fraudulent physics	UUID state history	Replay Detector	Stateful UUID tracking
Execution	Sign mathematically impossible telemetry	Enterprise MES Logging Pipeline	Traditional cryptography cannot verify physical truth	Streamlit SOC Alerts	ML Isolation Forest	Unsupervised Machine Learning

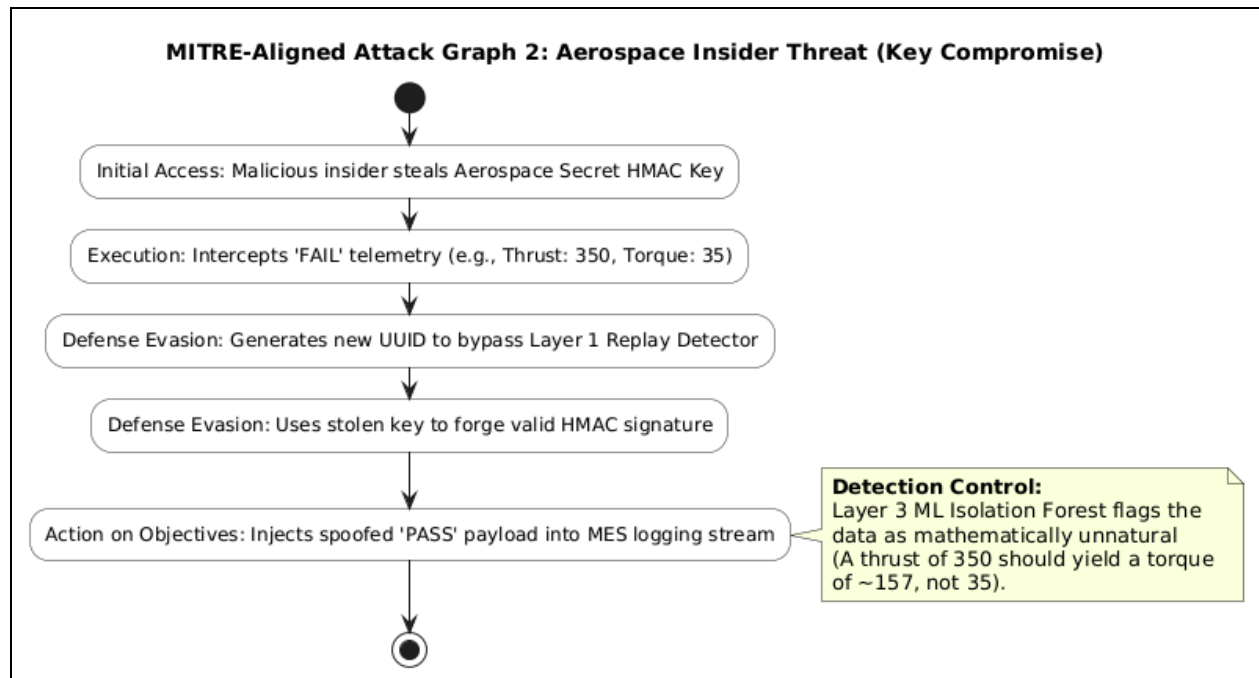
Threat Actor

Insider (e.g., rogue Aerospace engineer or sub-contractor).

Objective

Fraud / Manipulation (Forging perfectly signed, spoofed QA passes to cover up defective manufacturing).

Attack Graph



Affected Assets

Commercial Aircraft Edge Gateway, Key Management System, MES.

Detection Opportunities

Mathematical anomalies in physical telemetry correlations caught by Python algorithms.

Existing Weaknesses

Traditional cryptographic controls cannot detect if a valid Aerospace key is being used to sign physically impossible drilling data.

B.3 Task 3 — Defense-in-Depth Architecture

Control Layers

Layer	Control Family	Example Controls	Evidence Expected
1: Data and Cryptography	Payload Integrity & Origin	HMAC-SHA256 signing,	Edge gateway

		UUID v4 Nonces	code, crypto key lifecycle
2: Network and Perimeter	Network Segmentation	IPv4 strict binding (127.0.0.1), Factory VLAN isolation	Network topology diagram, broker configs
3: Host/Application/Endpoint	Application Logic & ML	Scikit-Learn Isolation Forest, Python Replay Set	Application source code, training baselines
4: Operations/Governance	Monitoring & Alerting	Streamlit Live Defense Dashboard, SOC Incident Response	Visual SOC grid, runtime threat logs

Control-to-Threat Mapping

Threat Scenario	Attack Stage	Proposed Control	Layer	Prevent/Detect/Respond
Topic Spoofing	Execution	HMAC-SHA 256 Payload Signing	Layer 1	Prevent

Replay Attack	Execution	UUID Nonce State Tracking	Layer 3	Prevent
Insider Key Theft	Action on Objectives	ML Isolation Forest Physics Check	Layer 3	Detect

B.4 Analyse — Gap Analysis and CVSS Risk Quantification

Current State

The native OPC UA smart tools stream unencrypted, unsigned JSON telemetry across the industrial network via a vulnerable MQTT broker.

Proposed State

Target architecture introduces an edge gateway to append UUIDs and HMAC signatures, while routing traffic through a Live Defense Dashboard equipped with an Isolation Forest ML engine to catch advanced physics anomalies.

Gap Table

Area	Current State	Proposed Target State	Remediation
Integrity	Plaintext JSON MQTT	HMAC-SHA256 Signatures	Implement edge payload signing
Replay Protection	None	UUID nonces & state tracking	Add Layer 1 Replay Detector

Insider Threat	Implicit trust of signed data	Physics correlation validation	Deploy Isolation Forest ML model
-----------------------	-------------------------------	--------------------------------	----------------------------------

Risk Register

Ris k ID	Threat	Asset	Impa ct	CVSS Score	Existing Control	Propose d Control	Residu al Risk
R1	MQTT Topic Spoofing (Tampering)	Telemetry Logging Pipeline	Critical	9.3 (Critical)	None (Plaintext MQTT)	HMAC-SHA256 Edge Signing	Low
R2	Replay Attack on QA Logs	Telemetry Logging Pipeline	High	6.5 (Medium)	None	Stateful UUID v4 Tracking	Low
R3	Insider Key Compromise	Edge Gateway / KMS	Critical	7.5 (High)	Traditional Cryptography	ML Isolation Forest Physics Check	Medium

Organizational Trade-off Analysis

Moving from implicit network trust to cryptographic payload signing introduces latency overhead and requires complex key management (KMS) across legacy edge devices. While this increases operational costs and maintenance friction, the trade-off is strictly necessary to comply with EASA safety regulations and prevent catastrophic data spoofing.

CVSS Scoring for Top Two Vulnerabilities

Vulnerability	Vector	Base Score	Severity	Explanation
1. MQTT Topic Spoofing (Unauthenticated Injection)	AV:A/AC:L/PR:N/UI:N/S:C/C:N/I:/H/A:H	9.3	Critical	Adjacent network access, no privileges required. Attacker injects forged data, causing high integrity impact (falsified QA logs) and high availability impact (crashing the MES parser). Scope is changed from the broker to the MES database.

2. Replay Attack on Structural QA Logs	AV:A/AC:L/ PR:N/U I:N/S:U /C:N/I: H/A:N	6.5	Medium	Adjacent network access. Attacker replays a previously recorded, valid "PASS" payload to cover up a current tool failure. High integrity impact due to fraudulent safety records, but no availability impact.
---	---	------------	---------------	---

CVSS Base Metric Table

Metric	Abbreviation	Student Selection	Explanation
Attack Vector	AV	A (Adjacent)	Attacker must be on the FAL factory floor local network (VLAN) to sniff and inject MQTT traffic.
Attack Complexity	AC	L (Low)	Unencrypted MQTT requires standard, easily available scripting tools (like Python paho-mqtt).

Privileges Required	PR	N (None)	The local broker does not require username/password authentication.
User Interaction	UI	N (None)	The attack is completely automated against the M2M (Machine-to-Machine) pipeline.
Scope	S	C (Changed)	The vulnerable component is the MQTT broker, but the impact breaches the Enterprise MES database (a separate system).
Confidentiality	C	N (None)	Telemetry interception does not expose sensitive PII or corporate secrets, just mechanical physics.
Integrity	I	H (High)	Falsifying structural QA passes entirely compromises the integrity of the aircraft manufacturing record.
Availability	A	H (High)	Flooding the broker or poisoning the MES halts the automated assembly line, causing total loss of availability.

Temporal Metric Table

Metric	Abbreviation	Student Selection	Explanation
Exploit Code Maturity	E	F (Functional)	No advanced weaponized exploit is required. Standard, widely available Python libraries (like paho-mqtt) are fully functional to execute this attack.
Remediation Level	RL	W (Workaround)	While the ultimate official fix is firmware-level HMAC signing, the immediate remediation available to Commercial Aircraft is a workaround: deploying the ML Isolation Forest model and strict VLAN segmentation.
Report Confidence	RC	C (Confirmed)	The vulnerability is fully confirmed and verified, as demonstrated by the successful spoofing attack in our simulated FAL factory environment.

Environmental Metric Table (Business Context)

Metric	Abbreviation	Student Selection	Explanation

Confidentiality Requirement	CR	L (Low)	Raw thrust numbers are not highly classified intellectual property.
Integrity Requirement	IR	H (High)	EASA/FAA compliance strictly mandates 100% accuracy in aircraft structural joint QA logs.
Availability Requirement	AR	H (High)	Factory downtime costs Commercial Aircraft millions of dollars per hour; high availability is critical.

Leadership Interpretation

Without cryptographic enforcement, our factory network currently operates on implicit trust, meaning any compromised laptop on the FAL can authorize defective aircraft parts. By implementing edge signing and Machine Learning validation, we mathematically guarantee QA data integrity and protect the enterprise from catastrophic safety failures, EASA non-compliance, and devastating reputational damage.

B.5 Reflect — Enterprise Constraints and Lifecycle Maintenance

Technical Friction

Legacy smart drilling units may lack the embedded compute power necessary to calculate HMAC-SHA256 signatures rapidly, potentially inducing latency into high-frequency telemetry streams. Generating training datasets for the Isolation Forest model requires highly accurate baseline mechanical data from the factory floor.

Organizational Friction

Aerospace environments require rigorous safety reviews. Pushing firmware updates (edge gateways) and new ML validation rules to the factory floor requires scheduled downtime and strict certification board approvals from EASA/FAA liaisons.

TCO Considerations

The enterprise must budget for ongoing ML model retraining (to prevent concept drift in mechanical baselines as drill bits wear down), KMS licensing for edge certificates, and dedicated SOC headcount to monitor the Streamlit dashboard.

Developer Experience Impact

Requiring developers to handle HMAC secret keys and UUID state tracking complicates local testing environments and slows down CI/CD pipelines. Bridging traditional aerospace engineering with modern Python-based data science pipelines requires cross-training.

Immediate High-Impact Remediation

Deploy the Isolation Forest ML Engine in Monitor-Only Mode. *Explanation:* This provides the highest risk reduction with the lowest implementation effort. It requires absolutely zero firmware updates or downtime for the legacy edge hardware, yet instantly provides the SOC with passive, real-time detection of mathematical anomalies and spoofing attacks.

References and Assumptions

- **Assumption 1:** Legacy smart drilling units support native OPC UA but lack hardware encryption capabilities.
- **Assumption 2:** The Enterprise MES database relies on the MQTT broker for QA logging without secondary out-of-band verification.
- **Reference 1:** EASA Part 21G Production Organization Approvals.
- **Reference 2:** MITRE ATT&CK Framework for Industrial Control Systems (ICS).
- **Reference 3:** FIRST (Forum of Incident Response and Security Teams) - Common Vulnerability Scoring System (CVSS) v3.1 Specification Document.
- **Reference 4:** Simon Brown - The C4 Model for Visualising Software Architecture.
- **Reference 5:** K. J. Biba - Integrity Considerations for Secure Computer Systems (Biba Integrity Model).
- **Reference 6:** Scikit-Learn - Isolation Forest Algorithm Documentation for Anomaly Detection.